

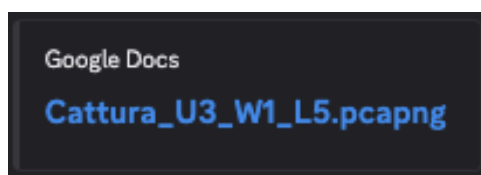
Analisi di log Wireshark

Sommario

- I SCOPO DEL PROGETTO 2
- 2 SVOLGIMENTO 2
 - 2.1 HIGH LEVEL ANALYSIS 2
 - 2.2 LOW LEVEL ANALYSIS 3
- 3 CONCLUSIONI 4

I Scopo del progetto

Il progetto prevede l'analisi di un'estrazione di log con l'utilizzo del software Wireshark.



Importato il file in Kali, lo apriamo e siamo pronti ad analizzarlo.

2 Svolgimento

2.1 High level analysis

Procediamo ad una prima analisi dei log:

35	36.775796938	192.168.200.150	192.168.200.100	TCP	74	22 → 55656	[SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=...
36	36.775797004	192.168.200.150	192.168.200.100	TCP	74	80 → 53062	[SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=...
37	36.775803786	192.168.200.100	192.168.200.150	TCP	66	55656 → 22	[ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535439 TSecr=4294952...
38	36.775813232	192.168.200.100	192.168.200.150	TCP	66	53062 → 80	[ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535439 TSecr=4294952...
39	36.775861964	192.168.200.100	192.168.200.150	TCP	66	41182 → 21	[RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535439 TSecr=42...

Identifichiamo subito l'host da cui partono le richieste 192.168.200.150 e l'host ricevente 192.168.200.100, tutte le richieste sono TCP.

54	36.776720715	192.168.200.100	192.168.200.150	TCP	74	54898 → 500	[SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535440...
55	36.776813123	192.168.200.150	192.168.200.100	TCP	60	587 → 34648	[RST, ACK] Seq=1 Ack=1 Win=0 Len=0
56	36.776843423	192.168.200.100	192.168.200.150	TCP	74	51534 → 487	[SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535440...
57	36.776904828	192.168.200.150	192.168.200.100	TCP	74	445 → 33042	[SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=...
58	36.776904922	192.168.200.150	192.168.200.100	TCP	60	256 → 49814	[RST, ACK] Seq=1 Ack=1 Win=0 Len=0
59	36.776904961	192.168.200.150	192.168.200.100	TCP	74	139 → 46990	[SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=...
60	36.776905004	192.168.200.150	192.168.200.100	TCP	60	143 → 33206	[RST, ACK] Seq=1 Ack=1 Win=0 Len=0
61	36.776905043	192.168.200.150	192.168.200.100	TCP	74	25 → 60632	[SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=...
62	36.776905082	192.168.200.150	192.168.200.100	TCP	60	110 → 49654	[RST, ACK] Seq=1 Ack=1 Win=0 Len=0
63	36.776905123	192.168.200.150	192.168.200.100	TCP	74	53 → 37282	[SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=...
64	36.776905162	192.168.200.150	192.168.200.100	TCP	60	500 → 54898	[RST, ACK] Seq=1 Ack=1 Win=0 Len=0
65	36.776914772	192.168.200.100	192.168.200.150	TCP	66	33042 → 445	[ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535440 TSecr=429495...

Notiamo l'insistenza di richieste ACK da host sorgente a host destinazione, con una sequenza randomica di di porte.

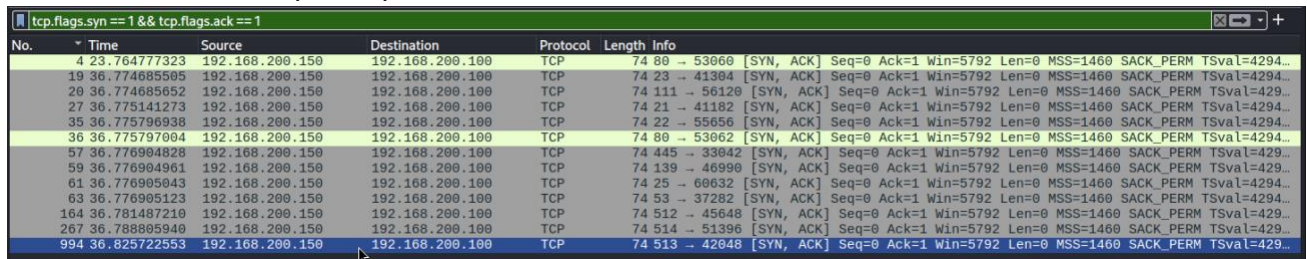
2081	36.878740280	192.168.200.100	192.168.200.150	TCP	74	39642 → 481	[SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535542...
2082	36.878807001	192.168.200.150	192.168.200.100	TCP	60	40 → 60640	[RST, ACK] Seq=1 Ack=1 Win=0 Len=0
2083	36.878896748	192.168.200.150	192.168.200.100	TCP	60	481 → 39642	[RST, ACK] Seq=1 Ack=1 Win=0 Len=0

L'ultima richiesta ha il counting 2000, questo mi fa pensare che le richieste sono state fatte facendo la scansione sulle 1000 porte più utilizzate.

Da questa prima analisi sommaria possiamo presupporre che è l'analisi di log di un attacco fatto con Nmap -sV (scansione porte aperte e versioni).

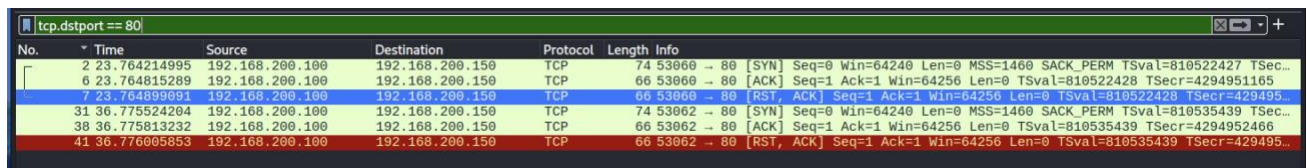
2.2 Low level analysis

Proviamo a verificare le porte aperte trovate:

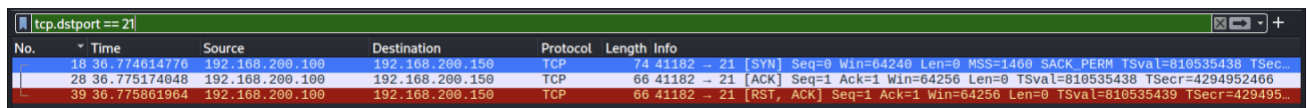


No.	Time	Source	Destination	Protocol	Length	Info
4	23.764777323	192.168.200.100	192.168.200.150	TCP	74	80 → 53060 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294...
19	36.774685505	192.168.200.150	192.168.200.100	TCP	74	23 → 41304 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294...
20	36.774685652	192.168.200.150	192.168.200.100	TCP	74	111 → 56120 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294...
27	36.775141273	192.168.200.150	192.168.200.100	TCP	74	21 → 41182 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294...
35	36.775796938	192.168.200.150	192.168.200.100	TCP	74	22 → 55656 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294...
36	36.775797004	192.168.200.150	192.168.200.100	TCP	74	80 → 53062 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294...
57	36.776904828	192.168.200.150	192.168.200.100	TCP	74	445 → 33042 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294...
59	36.776904961	192.168.200.150	192.168.200.100	TCP	74	139 → 46990 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294...
61	36.776905043	192.168.200.150	192.168.200.100	TCP	74	25 → 60632 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294...
63	36.776905123	192.168.200.150	192.168.200.100	TCP	74	53 → 37282 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294...
164	36.781487210	192.168.200.150	192.168.200.100	TCP	74	512 → 45648 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294...
267	36.788805940	192.168.200.150	192.168.200.100	TCP	74	514 → 51396 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294...
994	36.823722553	192.168.200.150	192.168.200.100	TCP	74	513 → 42048 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294...

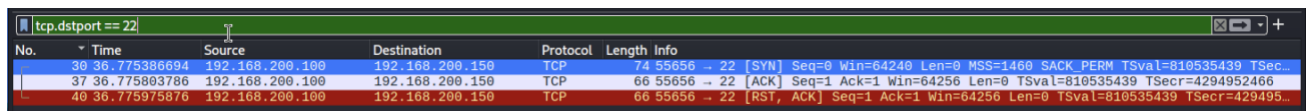
Ora proviamo a ricercare nello specifico porte in cui insistono servizi noti come porta 80, 443, 21, e altre.



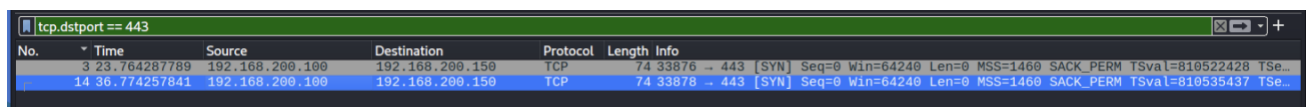
No.	Time	Source	Destination	Protocol	Length	Info
2	23.764214995	192.168.200.100	192.168.200.150	TCP	74	80 → 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810522427 TSecr=...
6	23.764815289	192.168.200.100	192.168.200.150	TCP	66	80 → 80 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810522428 TSecr=4294951165
7	23.764899091	192.168.200.100	192.168.200.150	TCP	66	80 → 80 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810522428 TSecr=429495...
31	36.775524204	192.168.200.100	192.168.200.150	TCP	74	80 → 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535439 TSecr=...
38	36.775813232	192.168.200.100	192.168.200.150	TCP	66	80 → 80 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535439 TSecr=4294952466
41	36.776005853	192.168.200.100	192.168.200.150	TCP	66	80 → 80 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535439 TSecr=429495...



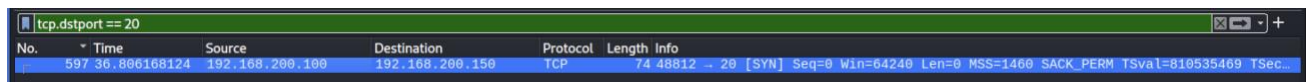
No.	Time	Source	Destination	Protocol	Length	Info
19	36.774614776	192.168.200.100	192.168.200.150	TCP	74	21 → 41182 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535438 TSecr=...
28	36.775174048	192.168.200.100	192.168.200.150	TCP	66	21 → 41182 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535438 TSecr=4294952166
39	36.775861964	192.168.200.100	192.168.200.150	TCP	66	21 → 41182 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535439 TSecr=429495...



No.	Time	Source	Destination	Protocol	Length	Info
36	36.775386694	192.168.200.100	192.168.200.150	TCP	74	22 → 55656 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535439 TSecr=...
37	36.775803786	192.168.200.100	192.168.200.150	TCP	66	22 → 55656 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535439 TSecr=4294952466
40	36.775975876	192.168.200.100	192.168.200.150	TCP	66	22 → 55656 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535439 TSecr=429495...

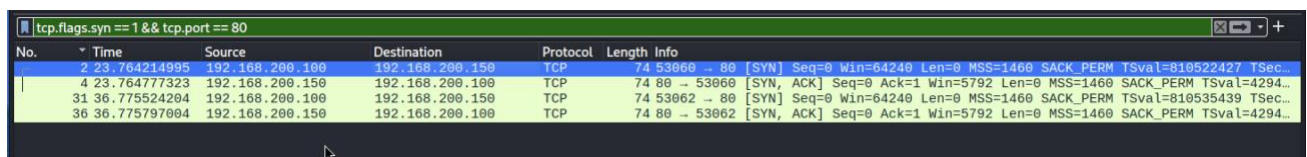


No.	Time	Source	Destination	Protocol	Length	Info
3	23.764287789	192.168.200.100	192.168.200.150	TCP	74	443 → 33876 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810522428 TSecr=...
14	36.774257841	192.168.200.100	192.168.200.150	TCP	74	443 → 33878 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535437 TSecr=...

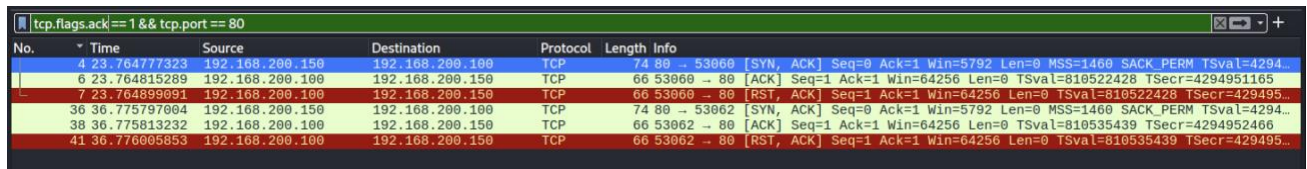


No.	Time	Source	Destination	Protocol	Length	Info
597	36.806168124	192.168.200.100	192.168.200.150	TCP	74	20 → 48812 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535469 TSecr=...

Di tutte queste richieste quella che attrae più la mia attenzione è la porta 80, infatti nmap (o software simile) insiste con più porte per cercare di accedere.



No.	Time	Source	Destination	Protocol	Length	Info
2	23.764214995	192.168.200.100	192.168.200.150	TCP	74	80 → 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810522427 TSecr=...
4	23.764777323	192.168.200.100	192.168.200.150	TCP	74	80 → 53060 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294...
31	36.775524204	192.168.200.100	192.168.200.150	TCP	74	80 → 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535439 TSecr=...
36	36.775797004	192.168.200.100	192.168.200.150	TCP	74	80 → 53062 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294...



No.	Time	Source	Destination	Protocol	Length	Info
4	23.764777323	192.168.200.150	192.168.200.100	TCP	74	80 → 80 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810522428 TSecr=4294951165
6	23.764815289	192.168.200.150	192.168.200.100	TCP	66	80 → 80 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810522428 TSecr=429495...
36	36.775797004	192.168.200.150	192.168.200.100	TCP	74	80 → 53062 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294...
41	36.776005853	192.168.200.150	192.168.200.100	TCP	66	80 → 80 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535439 TSecr=429495...

Probabilmente l'attaccante è riuscito ad effettuare una connessione attraverso la porta 80.

3 Conclusioni

Da questa estrazione di log abbiamo individuato che una macchina target 192.168.200.100 è stata oggetto di un attacco di port scanning, probabilmente con Nmap, da parte dell'host 192.168.200.150.

L'attaccante ha stabilito il percorso attraverso la porta 80 con il protocollo http.

Le remediation si sviluppano in 2 fasi differenti:

- Durante l'attacco
- Concluso l'attacco

Durante l'attacco apriamo una war room definite le risorse coinvolte, procediamo con il blocco dell'indirizzo IP e MAC della macchina attaccante per isolarla ed interrompere la connessione.

Procediamo anche con la chiusura delle porte non necessarie che non stanno erogando servizi.

Estromessa la macchina procediamo con una scansione per identificare possibili malware, sql injection o backdoor installati o aperti dall'attaccante.

Concluso l'attacco, per prevenire attacchi di questo tipo, il consiglio è l'installazione di sonde IPS che interrompono la comunicazione verso un host che effettua più di un numero prestabilito di richieste e allert per il dipartimento SOC nel caso in cui la sonda IPS si attiva.

In aggiunta studierei la topologia di rete per segmentare e isolare meglio gli host all'interno della rete, rivedrei le regole FW e installerei un monitoraggio attivo della rete.